

DPDP COMPLIANCE AUDIT

cal.com

Digital Personal Data Protection Act 2023



Grade D — At Risk

Scanned: 08 April 2026

Files indexed: 6387

CONFIDENTIAL — Internal Use Only

DPDP Compliance Scan Report

This codebase has 12 critical compliance gap(s) that require immediate attention under the Digital Personal Data Protection Act 2023. An additional 45 significant gap(s) were identified that should be addressed within 30 days. The estimated total remediation effort is 29.2–106.5 engineering days.

Total findings: 88

HIGH: 12

MEDIUM: 45

INFO: 3

PASS: 21

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	22/22 (100%)	PASS
Section 6(6)	8	8/8 (100%)	PASS
Section 8(1)	18	0/18 (0%)	FAIL
Section 8	10	2.0/10 (20%)	FAIL
Section 8(3)	8	4.0/8 (50%)	WARN
Section 8(4)	8	4.0/8 (50%)	WARN
Section 8(6)	8	5.6/8 (70%)	WARN
Section 9	6	0/6 (0%)	FAIL
Section 11	6	6/6 (100%)	PASS
Section 16	4	2.0/4 (50%)	WARN
Section 5	2	1.0/2 (50%)	WARN
Section 13 — Grievance Redressal	4	0/4 (0%)	FAIL

Estimated Total Remediation Effort: 29.2–106.5 engineering days

Data Flow Analysis

The following PII flow signals were inferred via static analysis (import/call adjacency). These are heuristic code-path chains, not proven runtime traces. Use them to guide developer review (confirm actual request → handler → service → database paths in your app).

Flow 1: Analytics SDK

PII fields: email, password, pii_field

provider-view.tsx → getServerSideProps.ts → UserRepository.ts → UserProfile.tsx

Flow 2: Analytics SDK

PII fields: password, mobile, email

SettingsLayoutAppDirClient.tsx → badge.tsx → utils.ts → ProfileRepository.ts → UserProfile.tsx

Flow 3: Analytics SDK

PII fields: password, mobile, phone

SettingsLayoutAppDirClient.tsx → Shell.tsx → SideBar.tsx → useBottomNavItems.ts

Flow 4: Analytics SDK

PII fields: password, mobile, phone

SettingsLayoutAppDirClient.tsx → Shell.tsx → Navigation.tsx → NavigationItem.tsx

Flow 5: Analytics SDK

PII fields: email, address, password

Payment.tsx → form.tsx → utils.ts → ProfileRepository.ts → UserProfile.tsx

Rule	Section	Severity	File
DEBUG_MODE_ENABLED	Section 8(1) — Security	MEDIUM	apps/api/v2/src/en v.ts
DEBUG_MODE_ENABLED	Section 8(1) — Security	HIGH	packages/embeds/ embed-core/src/e mbed.ts
CROSS_BORDER_TRANSFER_RISK	Section 16 — Cross-Border Transfer	MEDIUM	apps/api/v2/src/ee/ calendars/services /gcal.service.ts
PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT	Section 6 — Consent / Section 5 — Purpose Limitation	MEDIUM	apps/web/compon ents/getting-starte d/steps-views/User Profile.tsx
PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT	Section 6 — Consent / Section 5 — Purpose Limitation	HIGH	apps/web/modules /shell/useBottomN avItems.ts
PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT	Section 6 — Consent / Section 5 — Purpose Limitation	HIGH	apps/web/modules /shell/navigation/N avigationItem.tsx
PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT	Section 6 — Consent / Section 5 — Purpose Limitation	MEDIUM	packages/features/ eventtypes/reposi tories/eventTypeRe pository.ts
PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT	Section 6 — Consent / Section 5 — Purpose Limitation	HIGH	apps/web/modules /data-table/hooks/ useSegments.ts
PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT	Section 6 — Consent / Section 5 — Purpose Limitation	HIGH	apps/web/modules /ee/workflows/com ponents/agent-con figuration/compon ents/dialogs/
PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT	Section 6 — Consent / Section 5 — Purpose Limitation	HIGH	apps/web/modules /ee/workflows/com ponents/agent-con figuration/compon ents/tabs/Pho
PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT	Section 6 — Consent / Section 5 — Purpose Limitation	HIGH	packages/app-stor e/_components/Ap pCard.tsx
GRIEVANCE_OFFICER_MISSING	Section 13 — Grievance Redressal	HIGH	N/A
PLAINTEXT_PII_IN_LOGS	Section 8(1) — Security	HIGH	MULTIPLE
PASSWORD_NOT_HASHED	Section 8(1) — Security	HIGH	MULTIPLE

CHILDRENS_DATA_RISK	Section 9 — Children's Data	HIGH	apps/web/modules/ee/workflows/components/VoiceSelectionDialog.tsx
CHILDRENS_DATA_RISK	Section 9 — Children's Data	HIGH	apps/api/v2/src/modules/organizations/memberships/organizations-membership.contr
RETENTION_PARTIAL	Section 8(3) — Retention	MEDIUM	N/A
NO_ERROR_HANDLING_IN_AUTH	Section 8(6) — Breach	MEDIUM	apps/web/modules/auth/sso/provider-view.tsx
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/flags/features.repository.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/users/users.repository.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	LOW	packages/app-store/_utils/getCalendar.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	LOW	packages/features/availability/lib/getUserAvailability.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	LOW	packages/features/bookings/lib/host-filtering/findQualifiedHostsWithDelegationCr
PII_FLOW_TO_LOGGING	Section 8(1) — Security	LOW	packages/features/bookings/repositories/BookingRepository.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/busyTimes/lib/getBusyTimesFromLimits.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/busyTimes/services/getBusyTimes.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/calendar-subscription/lib/CalendarSubscriptionService.ts

PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/calendar-subscription/lib/cache/CalendarCacheWrapper.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/calendar-subscription/lib/sync/CalendarSyncService.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/calendar-subscription/lib/telemetry/CalendarTelemetryWrapper.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/ee/workflows/lib/reminders/reminderScheduler.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/flags/repositories/PrismaTeamFeatureRepository.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/flags/repositories/PrismaUserFeatureRepository.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/lib/sentryWrapper.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/lib/intervalLimits/limits/getPeriodStartDatesBetween.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/app-store/routing-forms/lib/formSubmissionUtils.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/emails/email-manager.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/bookings/lib/checkBookingLimits.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/bookings/lib/handleWebhookTrigger.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/bookings/lib/getAllCredentialsForUsersOnEvent/refreshCredentia

PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/bookings/lib/handleNewBooking/checkBookingAndDurationLimits.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/bookings/lib/handleNewBooking/createBooking.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/bookings/lib/handleNewBooking/ensureAvailableUsers.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/bookings/lib/handleNewBooking/findBookingQuery.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/bookings/lib/handleNewBooking/getBookingData.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/bookings/lib/handleNewBooking/getEventType.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/bookings/lib/handleNewBooking/getLocationValuesForDb.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/bookings/lib/handleNewBooking/getRequiresConfirmationFlags.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/bookings/lib/handleNewBooking/loadAndValidateUsers.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/bookings/lib/handleNewBooking/scheduleNoShowTriggers.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/bookings/lib/handleNewBooking/validateBookingTimesNotOutOfBou

PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/bookings/lib/handleNewBooking/validateEventLength.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/ee/round-robin/assignmentReason/AssignmentReasonRecorder.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/ee/workflows/lib/reminders/scheduleMandatoryReminder.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/webhooks/lib/getWebhooks.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/features/webhooks/lib/scheduleTrigger.ts
PII_FLOW_TO_LOGGING	Section 8(1) — Security	MEDIUM	packages/lib/server/defaultResponder.ts
INCOMPLETE_DELETION_COVERAGE	Section 8 — Data Principal Rights	MEDIUM	N/A
AUDIT_TRAIL_PARTIAL	Section 8(4) — Audit Trail	MEDIUM	packages/features/booking-audit/lib/repository/PrismaBookingAuditRepository.ts
THIRD_PARTY_PII_SHARING	Section 5 — Notice	MEDIUM	MULTIPLE
RETENTION_MISSING	Section 8(3) — Retention	MEDIUM	MULTIPLE
DATA_PORTABILITY_MISSING	Section 11 — Data Portability	LOW	N/A
CONSENT_MISSING	Section 6 — Consent	LOW	MULTIPLE
CHILDRENS_DATA_PATTERN	Section 9 — Children's Data	LOW	MULTIPLE
INTERNAL_ROUTE_PII_ACCESS	Section 7 — Legitimate Use	INFO	packages/features/eventtypes/lib/schemas.ts
INTERNAL_ROUTE_PII_ACCESS	Section 7 — Legitimate Use	INFO	packages/features/ee/billing/service/proration/tasker/ProrationEmailTasker.ts
INTERNAL_ROUTE_PII_ACCESS	Section 7 — Legitimate Use	INFO	apps/web/app/api/cron/credentials/route.ts

CONSENT_PRESENT	Section 6 — Consent	PASS	apps/web/modules/ee/workflows/components/WorkflowDetailsPage.tsx
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/web/modules/bookings/views/bookings-single-view.tsx
CONSENT_PRESENT	Section 6 — Consent	PASS	packages/app-store/exchange2013calendar/api/add.ts
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/api/v2/src/modules/router/controllers/router.controller.ts
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/web/modules/ee/teams/components/AddNewTeamMembers.tsx
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/web/modules/signup-view.tsx
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/web/modules/ee/workflows/views/WorkflowPage.tsx
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/web/modules/auth/oauth2/authenticate-view.tsx
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/web/modules/bookings/components/BookerWebWrapper.tsx
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/api/v2/src/ee/bookings/2024-04-15/controllers/bookings.controller.ts
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/web/modules/embed/components/Embed.tsx
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/api/v2/src/ee/calendars/controllers/calendars.controller.ts
CONSENT_PRESENT	Section 6 — Consent	PASS	packages/platform/atoms/booker/BookerPlatformWrapper.tsx

CONSENT_PRESENT	Section 6 — Consent	PASS	apps/web/modules/ee/workflows/components/WorkflowStepContainer.tsx
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/web/modules/team/type-view.tsx
CONSENT_PRESENT	Section 6 — Consent	PASS	packages/app-store/exchange/calendar/api/_postAdd.ts
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/web/components/apps/routing-forms/TestForm.tsx
CONSENT_WITHDRAWAL_PRESENT	Section 6(6) — Consent Withdrawal	PASS	apps/api/v2/src/modules/billing/controllers/billing.controller.ts
DELETION_MECHANISM_PRESENT	Section 8 — Data Principal Rights	PASS	N/A
BREACH_INDICATORS_ADEQUATE	Section 8(6) — Breach	PASS	N/A
DATA_ACCESS_PRESENT	Section 11 — Right to Access	PASS	apps/web/modules/members/getOrgMembersPageData.ts

43 finding(s) show rule-engine fallback text only (LLM enrichment cap or parse failure).

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 1 — Critical (64–223 hours)

Fix immediately — these represent the highest legal exposure.

- Debug Mode Enabled — src/embed.ts (4–16 hrs)
- Pii Flow To Analytics Without Consent — shell/useBottomNavItems.ts (4–16 hrs)
- Pii Flow To Analytics Without Consent — navigation/NavigationItem.tsx (4–16 hrs)
- Pii Flow To Analytics Without Consent — hooks/useSegments.ts (4–16 hrs)
- Pii Flow To Analytics Without Consent — dialogs/BuyNumberDialog.tsx (4–16 hrs)
- Pii Flow To Analytics Without Consent — tabs/PhoneNumberTab.tsx (4–16 hrs)
- Pii Flow To Analytics Without Consent — _components/AppCard.tsx (4–16 hrs)
- Grievance Officer Missing (1–4 hrs)
- Plaintext Pii In Logs — MULTIPLE (29–86 hrs)
- Password Not Hashed — MULTIPLE (2–5 hrs)
- Childrens Data Risk — components/VoiceSelectionDialog.tsx (2–8 hrs)
- Childrens Data Risk — memberships/organizations-membership.controller.e2e-spec.ts (2–8 hrs)

Week 2 — High Priority (93–365 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- Debug Mode Enabled — src/env.ts (2–8 hrs)
- Cross Border Transfer Risk — services/gcal.service.ts (4–12 hrs)
- Pii Flow To Analytics Without Consent — steps-views/UserProfile.tsx (2–8 hrs)
- Pii Flow To Analytics Without Consent — repositories/eventTypeRepository.ts (2–8 hrs)
- Retention Partial (2–8 hrs)
- No Error Handling In Auth — sso/provider-view.tsx (1–3 hrs)
- Pii Flow To Logging — flags/features.repository.ts (2–8 hrs)
- Pii Flow To Logging — users/users.repository.ts (2–8 hrs)
- Pii Flow To Logging — lib/getBusyTimesFromLimits.ts (2–8 hrs)
- Pii Flow To Logging — services/getBusyTimes.ts (2–8 hrs)
- Pii Flow To Logging — lib/CalendarSubscriptionService.ts (2–8 hrs)
- Pii Flow To Logging — cache/CalendarCacheWrapper.ts (2–8 hrs)
- Pii Flow To Logging — sync/CalendarSyncService.ts (2–8 hrs)
- Pii Flow To Logging — telemetry/CalendarTelemetryWrapper.ts (2–8 hrs)
- Pii Flow To Logging — reminders/reminderScheduler.ts (2–8 hrs)
- Pii Flow To Logging — repositories/PrismaTeamFeatureRepository.ts (2–8 hrs)
- Pii Flow To Logging — repositories/PrismaUserFeatureRepository.ts (2–8 hrs)
- Pii Flow To Logging — lib/sentryWrapper.ts (2–8 hrs)
- Pii Flow To Logging — utils/getPeriodStartDatesBetween.ts (2–8 hrs)
- Pii Flow To Logging — lib/formSubmissionUtils.ts (2–8 hrs)
- Pii Flow To Logging — emails/email-manager.ts (2–8 hrs)
- Pii Flow To Logging — lib/checkBookingLimits.ts (2–8 hrs)
- Pii Flow To Logging — lib/handleWebhookTrigger.ts (2–8 hrs)
- Pii Flow To Logging — getAllCredentialsForUsersOnEvent/refreshCredentials.ts (2–8 hrs)
- Pii Flow To Logging — handleNewBooking/checkBookingAndDurationLimits.ts (2–8 hrs)
- Pii Flow To Logging — handleNewBooking/createBooking.ts (2–8 hrs)
- Pii Flow To Logging — handleNewBooking/ensureAvailableUsers.ts (2–8 hrs)
- Pii Flow To Logging — handleNewBooking/findBookingQuery.ts (2–8 hrs)
- Pii Flow To Logging — handleNewBooking/getBookingData.ts (2–8 hrs)
- Pii Flow To Logging — handleNewBooking/getEventType.ts (2–8 hrs)
- Pii Flow To Logging — handleNewBooking/getLocationValuesForDb.ts (2–8 hrs)
- Pii Flow To Logging — handleNewBooking/getRequiresConfirmationFlags.ts (2–8 hrs)
- Pii Flow To Logging — handleNewBooking/loadAndValidateUsers.ts (2–8 hrs)
- Pii Flow To Logging — handleNewBooking/scheduleNoShowTriggers.ts (2–8 hrs)
- Pii Flow To Logging — handleNewBooking/validateBookingTimeIsNotOutOfBounds.ts (2–8 hrs)
- Pii Flow To Logging — handleNewBooking/validateEventLength.ts (2–8 hrs)
- Pii Flow To Logging — assignmentReason/AssignmentReasonRecorder.ts (2–8 hrs)
- Pii Flow To Logging — reminders/scheduleMandatoryReminder.ts (2–8 hrs)
- Pii Flow To Logging — lib/getWebhooks.ts (2–8 hrs)
- Pii Flow To Logging — lib/scheduleTrigger.ts (2–8 hrs)
- Pii Flow To Logging — server/defaultResponder.ts (2–8 hrs)
- Incomplete Deletion Coverage (2–8 hrs)
- Audit Trail Partial — repository/PrismaBookingAuditRepository.ts (2–8 hrs)
- Retention Missing — MULTIPLE (6–22 hrs)

Week 3 — Significant (43–128 hours)

Schedule in sprint — requires more engineering time.

■ Third Party Pii Sharing — MULTIPLE (43–128 hrs)

Week 4 — Advisory (34–136 hours)

Address before next compliance review.

- Pii Flow To Logging — _utils/getCalendar.ts (1–4 hrs)
- Pii Flow To Logging — lib/getUserAvailability.ts (1–4 hrs)
- Pii Flow To Logging — host-filtering/findQualifiedHostsWithDelegationCredentials.ts (1–4 hrs)
- Pii Flow To Logging — repositories/BookingRepository.ts (1–4 hrs)
- Data Portability Missing (2–8 hrs)
- Consent Missing — MULTIPLE (20–80 hrs)
- Childrens Data Pattern — MULTIPLE (8–32 hrs)

Total estimated remediation effort: 234–852 hours (29.2–106.5 engineering days)

Details

Finding 1 of 88

[Section 8(1) — Security]

1. [MEDIUM] DEBUG_MODE_ENABLED — apps / api / v2 / src / env.ts:4

Evidence snippet: NODE_ENV: "development" | "production";

Estimated fix time: 2–8 hours

Debug mode is enabled. In production, this exposes interactive debuggers (Flask/Werkzeug), detailed stack traces, and internal system information to users. Flask debug mode specifically allows arbitrary code execution via the Werkzeug console. DPDP Section 8(1) requires appropriate security measures to protect personal data.

Risk:

Debug mode, if enabled in production, can expose sensitive system information and potentially allow arbitrary code execution, violating DPDP Section 8(1)'s requirement for appropriate security measures to protect personal data.

Fix:

1. Ensure that the DEBUG_MODE environment variable (or equivalent configuration) is set to false in production environments for apps/api/v2/src/env.ts.

DPDP:

Section 8(1) — Requires appropriate security measures to protect personal data.

Example:

```
// Example for a typical Node.js environment
const isProduction = process.env.NODE_ENV === 'production';
const debugMode = isProduction ? false : process.env.DEBUG_MODE === 'true';
if (debugMode) { console.warn('Debug mode is enabled in a non-production environment.')} else {
// Disable debug features }
```

Finding 2 of 88

[Section 8(1) — Security]

2. [HIGH] DEBUG_MODE_ENABLED — packages / embeds / embed-core / src / embed.ts:358

Evidence snippet: // cal.embed.logging=1 enabled logging in parent and by setting debug=true in iframe, it enables logging in iframe(child) as well

Estimated fix time: 4–16 hours

Debug mode is enabled. In production, this exposes interactive debuggers (Flask/Werkzeug), detailed stack traces, and internal system information to users. Flask debug mode specifically allows arbitrary code execution via the Werkzeug console. DPDP Section 8(1) requires appropriate security measures to protect personal data.

Risk:

The embed core library allows for debug and UI debug modes to be enabled, which could expose internal system information if not properly managed in production, thus potentially violating DPDP Section 8(1) security requirements.

Fix:

1. In production deployments, ensure that the `debug` and `uiDebug` options are not passed or are set to `false` when initializing the embed configuration.
2. Review the initialization logic for the embed component to explicitly disable debug features in production environments.
3. Consider removing or deprecating the `debug` and `uiDebug` flags if they are not essential for production monitoring.

DPDP:

Section 8(1) — Requires appropriate security measures to protect personal data.

Example:

```
// Example of disabling debug mode during initialization: const embedConfig = { // ... other configurations debug: false, // Explicitly set to false uiDebug: false, // Explicitly set to false }; // Initialize embed with the configuration cal.embed(embedConfig);
```

Finding 3 of 88

[Section 16 — Cross-Border Transfer]

3. [MEDIUM] CROSS_BORDER_TRANSFER_RISK — apps / api / v2 / src / ee / calendars / services /

gcal.service.ts:21

Evidence snippet: "https://www.googleapis.com/auth/calendar.readonly",

Estimated fix time: 4–12 hours

Foreign cloud storage/CDN detected with PII models in repo. Cross-border transfer risk.

Risk:

The finding suggests a risk of cross-border transfer of PII due to foreign cloud storage, which is a violation of DPDP Section 16. Without evidence of such services in the provided code, this risk cannot be confirmed.

Fix:

1. Review the deployment configuration and infrastructure to identify any third-party cloud storage or CDN services used for storing or processing personal data.
2. If foreign cloud services are used, ensure they comply with DPDP cross-border transfer requirements, such as standard contractual clauses or other approved mechanisms.
3. Document the purpose and legal basis for any cross-border data transfers.

DPDP:

Section 16 — Governs the conditions under which personal data may be transferred across borders.

Example:

Not applicable as the code does not contain the described functionality.

Finding 4 of 88

[Section 6 — Consent / Section 5 — Purpose Limitation]

4. [MEDIUM] PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT — apps / web / components / getting-started / steps-views / UserProfile.tsx

Estimated fix time: 2–8 hours

PII flows from sso/provider-view.tsx to analytics service (steps-views/UserProfile.tsx) through 3 intermediate file(s). No analytics-specific consent detected on this flow path. DPDP Section 6 requires explicit consent for analytics processing separate from functional/auth consent.

Risk:

Flowing PII to analytics services without explicit user consent violates DPDP Section 6 and Section 5, undermining user trust and potentially leading to unauthorized data processing.

Fix:

1. Implement a clear consent mechanism for analytics tracking, specifically for PII, before data is sent.
2. Review the data flow from SSO/provider authentication to the analytics service to identify all PII being transmitted.
3. Ensure that the purpose of analytics tracking is clearly communicated to the user and aligns with the consent obtained.

DPDP:

Section 6 — Requires explicit consent for processing personal data, and Section 5 — Personal data shall be processed for specified, explicit and legitimate purposes.

Example:

```
// Example of conditional analytics tracking based on consent (React) import React, {
useContext } from 'react'; import { AnalyticsContext } from '../AnalyticsContext'; // Assume
this context holds consent status const UserProfile = ({ ssoData }) => { const {
analyticsConsentGiven } = useContext(AnalyticsContext); const trackProfileCompletion = () => {
if (analyticsConsentGiven && ssoData) { // Send PII to analytics only if consent is given
analytics.track('UserProfileCompleted', { userId: ssoData.userId, email: ssoData.email }); }
}; // Call trackProfileCompletion when appropriate, e.g., after form submission //
trackProfileCompletion(); return ( <div> /* User profile form elements */ </div> ); };
```

Finding 5 of 88

[Section 6 — Consent / Section 5 — Purpose Limitation]

5. [HIGH] PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT — apps / web / modules / shell / useBottomNavItems.ts:15

Evidence snippet: Calls posthog.capture, indicating data is being sent to an analytics service.

Estimated fix time: 4–16 hours

PII flows from (settings-layout)/SettingsLayoutAppDirClient.tsx to analytics service (shell/useBottomNavItems.ts) through 3 intermediate file(s). No analytics-specific consent detected on this flow path. DPDP Section 6 requires explicit consent for analytics processing separate from functional/auth consent.

Risk:

Personal data is being sent to an analytics service without explicit user consent, violating DPDP Section 6. This can lead to unauthorized data processing and potential loss of user trust.

Fix:

1. Implement a consent management system to obtain explicit user consent before sending any PII to PostHog.
2. Conditionally capture events using `posthog.capture` only after consent is granted.
3. Review all `posthog.capture` calls in `useBottomNavItems.ts` and related components to ensure only non-PII data is sent or that consent is properly handled.

DPDP:

Section 6 — Consent: Explicit consent is required for the processing of personal data for purposes such as analytics.

Example:

```
import posthog from 'posthog-js'; import { useConsent } from '@calcom/lib/hooks/useConsent';
// Assuming a consent hook exists const MyComponent = () => { const { hasAnalyticsConsent } =
useConsent(); const trackEvent = (eventName: string, eventProperties?: any) => { if
(hasAnalyticsConsent) { posthog.capture(eventName, eventProperties); } }; // ... rest of
component logic return ( <button onClick={() => trackEvent('button_click', { buttonName:
'Submit' })}> Submit </button> ); };
```

Finding 6 of 88

[Section 6 — Consent / Section 5 — Purpose Limitation]

6. [HIGH] PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT — apps / web / modules / shell / navigation / NavigationItem.tsx:35

Evidence snippet: Calls posthog.capture, indicating data is being sent to an analytics service.

Estimated fix time: 4–16 hours

PII flows from (settings-layout)/SettingsLayoutAppDirClient.tsx to analytics service (navigation/NavigationItem.tsx) through 3 intermediate file(s). No analytics-specific consent detected on this flow path. DPDP Section 6 requires explicit consent for analytics processing separate from functional/auth consent.

Risk:

Personal data is being sent to an analytics service without explicit user consent, violating DPDP Section 6. This can lead to unauthorized data processing and potential loss of user trust.

Fix:

1. Implement a consent management system to obtain explicit user consent before sending any PII to PostHog.
2. Conditionally capture events using `posthog.capture` only after consent is granted.
3. Review all `posthog.capture` calls in `NavigationItem.tsx` and related components to ensure only non-PII data is sent or that consent is properly handled.

DPDP:

Section 6 — Consent: Explicit consent is required for the processing of personal data for purposes such as analytics.

Example:

```
import posthog from 'posthog-js'; import { useConsent } from '@calcom/lib/hooks/useConsent';  
// Assuming a consent hook exists const NavigationItem = ({ item }) => { const {  
hasAnalyticsConsent } = useConsent(); const handleClick = () => { if (hasAnalyticsConsent) {  
posthog.capture('navigation_item_click', { itemName: item.name }); } // ... other navigation  
logic }; return <div onClick={handleClick}>{item.label}</div>; };
```

Finding 7 of 88

[Section 6 — Consent / Section 5 — Purpose Limitation]

7. [MEDIUM] PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT — packages / features / eventtypes / repositories / eventTypeRepository.ts:14

Evidence snippet: Uses logger.info, which could potentially log PII if not carefully managed, but doesn't directly indicate flow to an analytics service.

Estimated fix time: 2–8 hours

PII flows from services/shared-routing-form-response.service.ts to analytics service (repositories/eventTypeRepository.ts) through 5 intermediate file(s). No analytics-specific consent detected on this flow path. DPDP Section 6 requires explicit consent for analytics processing separate from functional/auth consent.

Risk:

The provided code snippet for `eventTypeRepository.ts` does not contain direct evidence of PII flowing to an analytics service without consent. The finding might be based on broader code context not visible here.

Fix:

1. Review the full code path from `services/shared-routing-form-response.service.ts` to `eventTypeRepository.ts` to identify any PII being logged or sent to analytics.
2. If PII is being logged, ensure it is anonymized or pseudonymized before being sent to any analytics service.
3. Implement consent checks before any data, potentially including PII, is processed by analytics services.

DPDP:

Section 6 — Consent: Explicit consent is required for the processing of personal data for purposes such as analytics.

Example:

```
import logger from '@calcom/lib/logger'; // Assuming 'data' might contain PII and is passed to
an analytics service elsewhere const processEventType = async (data: any) => { // ...
processing logic ... if (process.env.NODE_ENV === 'production') { // Example: Only log
non-sensitive data or anonymized data to analytics const analyticsData = { eventType: data.eventType,
data.id, name: data.name }; // Example of anonymization logger.info('Event type processed',
analyticsData); // Ensure this logger call does NOT send PII to an analytics service without
consent } // ... rest of logic ... };
```


Finding 8 of 88

[Section 6 — Consent / Section 5 — Purpose Limitation]

8. [HIGH] PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT — apps / web / modules / data-table / hooks / useSegments.ts:13**Evidence snippet:** The `useSegments` hook is defined, but the provided snippet does not show any calls to `posthog.capture` or explicit PII handling related to analytics.**Estimated fix time:** 4–16 hours

PII flows from components/WorkflowDetailsPage.tsx to analytics service (hooks/useSegments.ts) through 5 intermediate file(s). No analytics-specific consent detected on this flow path. DPDP Section 6 requires explicit consent for analytics processing separate from functional/auth consent.

Risk:

While the `posthog-js` library is imported, the provided code snippet for `useSegments.ts` does not show direct evidence of PII flowing to an analytics service without consent. The actual PII flow might occur in other parts of the hook or be triggered conditionally.

Fix:

1. Review the implementation of the `useSegments` hook to identify any calls to `posthog.capture` that might send PII.
2. Implement a consent mechanism (e.g., a `useConsent` hook) to control when `posthog.capture` is called.
3. Ensure that any PII captured by `posthog` is only sent after explicit user consent has been obtained.

DPDP:

Section 6 — Consent: Explicit consent is required for the processing of personal data for purposes such as analytics.

Example:

```
import posthog from 'posthog-js'; import { useConsent } from '@calcom/lib/hooks/useConsent';  
// Assuming a consent hook exists const useSegments = () => { const { hasAnalyticsConsent } =  
useConsent(); const trackSegmentUsage = (segmentName: string) => { if (hasAnalyticsConsent) {  
posthog.capture('segment_used', { segment: segmentName }); } }; // ... rest of hook logic that  
might call trackSegmentUsage return { trackSegmentUsage }; };
```

Finding 9 of 88

[Section 6 — Consent / Section 5 — Purpose Limitation]

9. [HIGH] PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT — apps / web / modules / ee / workflows / components / agent-configuration / components / dialogs / BuyNumberDialog.tsx**Estimated fix time:** 4–16 hours

PII flows from components/WorkflowDetailsPage.tsx to analytics service (dialogs/BuyNumberDialog.tsx) through 4 intermediate file(s). No analytics-specific consent detected on this flow path. DPDP Section 6 requires explicit consent for analytics processing separate from functional/auth consent.

Risk:

Manual review required. Rule 'PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT' fired on apps/web/modules/ee/workflows/components/agent-configuration/components/dialogs/BuyNumberDialog.tsx — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 6 — Consent / Section 5 — Purpose Limitation

Finding 10 of 88

[Section 6 — Consent / Section 5 — Purpose Limitation]

10. [HIGH] PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT — apps / web / modules / ee / workflows / components / agent-configuration / components / tabs / PhoneNumberTab.tsx

Estimated fix time: 4–16 hours

PII flows from components/WorkflowDetailsPage.tsx to analytics service (tabs/PhoneNumberTab.tsx) through 3 intermediate file(s). No analytics-specific consent detected on this flow path. DPDP Section 6 requires explicit consent for analytics processing separate from functional/auth consent.

Risk:

Manual review required. Rule 'PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT' fired on apps/web/modules/ee/workflows/components/agent-configuration/components/tabs/PhoneNumberTab.tsx — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 6 — Consent / Section 5 — Purpose Limitation

Finding 11 of 88

[Section 6 — Consent / Section 5 — Purpose Limitation]

11. [HIGH] PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT — packages / app-store / _components / AppCard.tsx

Estimated fix time: 4–16 hours

PII flows from booker-embed/useGetRoutingFormUrlProps.tsx to analytics service (_components/AppCard.tsx) through 6 intermediate file(s). No analytics-specific consent detected on this flow path. DPDP Section 6 requires explicit consent for analytics processing separate from functional/auth consent.

Risk:

Manual review required. Rule 'PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT' fired on packages/app-store/_components/AppCard.tsx — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 6 — Consent / Section 5 — Purpose Limitation

Finding 12 of 88

[Section 13 — Grievance Redressal]

12. [HIGH] GRIEVANCE_OFFICER_MISSING — N / A

Estimated fix time: 1–4 hours

No compliant Grievance Officer / DPO publication found. A PASS requires grievance-related text or a dedicated route **and** a contact email or dedicated grievance/DPO URL. Tiny repos without a grievance route are not marked PASS.

Risk:

Manual review required. Rule 'GRIEVANCE_OFFICER_MISSING' fired on see finding scope — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 13 — Grievance Redressal

Finding 13 of 88

[Section 8(1) — Security]

13. [HIGH] PLAINTEXT_PII_IN_LOGS — MULTIPLE

Estimated fix time: 29–86 hours

Affected files (93):

- apps/api/v2/src/modules/oauth-clients/controllers/oauth-client-users/oauth-client-users.controller.ts
- apps/api/v2/src/modules/oauth-clients/services/oauth-flow.service.ts
- apps/api/v2/src/modules/organizations/delegation-credentials/services/organizations-delegation-credential.service.ts
- apps/web/app/api/auth/saml/token/route.ts
- apps/web/app/api/auth/saml/userinfo/route.ts
- apps/web/app/api/auth/signup/handlers/calcomSignupHandler.ts
- ... and 87 more files

PII keyword appears in logging call. Detected in 93 files: oauth-client-users.controller.ts, oauth-flow.service.ts, organizations-delegation-credential.service.ts, route.ts and 89 more

Risk:

Logging PII such as IP addresses without proper sanitization or anonymization can lead to unauthorized disclosure of personal data, violating data minimization and security principles.

Fix:

1. Modify `AppLoggerMiddleware` to anonymize or hash IP addresses before logging.
2. Implement a configuration to control which fields are logged, excluding sensitive PII by default.
3. Review all logging statements across the codebase to ensure no plaintext PII is being logged.

DPDP:

Section 8(1) — Security

Example:

```
import { Logger } from "@nestjs/common"; import { Request, NextFunction } from "express";
import { Response } from "@calcom/platform-types"; import crypto from "crypto"; // ... inside
AppLoggerMiddleware class ... response.on("close", () => { const { ip, method, originalUrl } =
request; const userAgent = request.get("user-agent") || ""; const { statusCode } = response;
const contentLength = response.get("content-length"); const anonymizedIp =
crypto.createHash('sha256').update(ip).digest('hex'); // Example anonymization
this.logger.log(`${method} ${originalUrl} ${statusCode} ${contentLength} - ${userAgent}
${anonymizedIp}`); });
```

Finding 14 of 88

[Section 8(1) — Security]

14. [HIGH] PASSWORD_NOT_HASHED — MULTIPLE

Estimated fix time: 2–5 hours

Affected files (3):

- apps/web/modules/users/components/AdminPasswordBanner.tsx
- packages/features/bookings/lib/handleSeats/reschedule/rescheduleSeatedBooking.ts
- packages/trpc/server/routers/viewer/me/deleteMe.schema.ts

Model file has password field but no hash/bcrypt/argon/pbkdf2/scrypt/encrypt reference.

Detected in 3 files: AdminPasswordBanner.tsx, rescheduleSeatedBooking.ts, deleteMe.schema.ts

Risk:

Storing or handling passwords in plaintext or without proper hashing mechanisms poses a significant security risk, as compromised credentials can lead to unauthorized access and data breaches.

Fix:

1. Implement password hashing (e.g., bcrypt, Argon2) in the service layer before storing any password-like fields.
2. Update the `credentialForCalendarRepositorySelect` to exclude sensitive fields like 'key' unless absolutely necessary and properly secured.
3. Review the `getBookingReferencesIncludeSensitiveCredentials` method to ensure sensitive credentials are only accessed and handled with appropriate security controls.

DPDP:

Section 8(1) — Security

Example:

```
import bcrypt from 'bcrypt'; // ... inside a service or repository method where user data is saved ...
async createUser(userData: UserInput) {
  const saltRounds = 10;
  const hashedPassword = await bcrypt.hash(userData.password, saltRounds);
  await this.dbWrite.prisma.user.create({
    data: { ...userData, password: hashedPassword },
  });
}
```

Finding 15 of 88

[Section 9 — Children's Data]

15. [HIGH] CHILDRENS_DATA_RISK — apps / web / modules / ee / workflows / components /

VoiceSelectionDialog.tsx

Estimated fix time: 2–8 hours

Age/DOB field detected but no age verification or parental consent logic found.

Risk:

Processing children's data without age verification or parental consent mechanisms is a direct violation of data protection regulations concerning minors, potentially leading to severe legal penalties and reputational damage.

Fix:

1. Implement age verification logic within the `VoiceSelectionDialog` component or its parent component.
2. If children's data is processed, integrate a parental consent flow before collecting or processing any personal information.
3. Consult with legal counsel to ensure compliance with specific age thresholds and consent requirements for children's data.

DPDP:

Section 9 — Children's Data

Example:

```
// Example for age verification within a form component import React, { useState } from
'react'; function AgeVerificationForm() { const [age, setAge] = useState(''); const
[consentGiven, setConsentGiven] = useState(false); const handleAgeChange = (event) =>
setAge(event.target.value); const handleConsentChange = (event) =>
setConsentGiven(event.target.checked); const isAdult = parseInt(age, 10) >= 18; return ( <div>
<input type="number" value={age} onChange={handleAgeChange} placeholder="Your Age" />
{!isAdult && ( <label> <input type="checkbox" checked={consentGiven}
onChange={handleConsentChange} /> Parent/Guardian Consent </label> )} { /* Proceed button logic
based on isAdult and consentGiven */ } </div> ); }
```

Finding 16 of 88

[Section 9 — Children's Data]

16. [HIGH] CHILDRENS_DATA_RISK — apps / api / v2 / src / modules / organizations / memberships / organizations-membership.controller.e2e-spec.ts

Estimated fix time: 2–8 hours

Age/DOB field detected but no age verification or parental consent logic found.

Risk:

Processing children's data without age verification or parental consent mechanisms is a direct violation of data protection regulations concerning minors, potentially leading to severe legal penalties and reputational damage.

Fix:

1. Review the test cases in `organizations-membership.controller.e2e-spec.ts` to identify any scenarios involving minors' data.
2. If minors' data is handled, ensure that appropriate age verification and parental consent mechanisms are tested.
3. Update the controller and service logic to include age verification and parental consent flows if children's data is processed.

DPDP:

Section 9 — Children's Data

Example:

```
// This is a test file, so the fix involves ensuring tests cover consent logic. // The actual implementation fix would be in the controller/service layer.
describe('OrganizationsMembershipController', () => { // ... existing tests ... it('should require parental consent for minor membership creation', async () => { const minorData = { name: 'Child User', age: 10 }; // Assuming age is a field const parentData = { name: 'Parent User', email: 'parent@example.com' }; // Mock parent consent mechanism // ... mock consent service ... await request(app.getHttpServer()).post('/organizations/memberships').send({ ...minorData, parentEmail: parentData.email, parentConsent: true }).expect(201); }); });
```

Finding 17 of 88

[Section 8(3) — Retention]

17. [MEDIUM] RETENTION_PARTIAL — N / A:14**Evidence snippet:** Uses WebhookSchema to pick fields, potentially including PII.**Estimated fix time:** 2–8 hours

Retention signals found in 28 model(s) but 7 PII model(s) have no retention policy. Uncovered: EventReservationSchema.tsx, findBookingQuery.ts, attendeeRescheduleSeatedBooking.ts.

Risk:

The absence of a data retention policy means personal data may be stored indefinitely, increasing the risk of unauthorized access or misuse and violating DPDP Section 8(3). This can lead to significant privacy breaches and regulatory penalties.

Fix:

1. Implement a data retention policy for PII, defining how long different types of personal data are stored and when they should be deleted.
2. Integrate the retention policy into the data lifecycle management, ensuring automated deletion or anonymization of data once its retention period expires.
3. Document the retention periods and the rationale behind them, aligning with business needs and DPDP requirements.
4. Regularly audit data storage to ensure compliance with the defined retention policies.

DPDP:

Section 8(3) — Retention: Personal data shall not be kept longer than necessary for the purpose for which it is processed.

Example:

```
// Example of defining a retention policy in a configuration file // This is a conceptual
example as the actual implementation would depend on the storage and data management system.
const dataRetentionPolicies = { user_data: { duration_days: 365, applies_to: ['user_profile',
'booking_history'] }, audit_logs: { duration_days: 90, applies_to: ['system_logs'] },
temporary_data: { duration_days: 7, applies_to: ['session_data'] } }; function
getDataRetentionPeriod(dataType: string): number | null { return
dataRetentionPolicies[dataType]?.duration_days || null; }
```

Finding 18 of 88

[Section 8(6) — Breach]

18. [MEDIUM] NO_ERROR_HANDLING_IN_AUTH — apps / web / modules / auth / sso / provider-view.tsx:26**Evidence snippet:** Handles 'saml' provider, checks for email and SAML enablement, then calls signIn.**Estimated fix time:** 1–3 hours

Auth routes have no try/catch or try/except blocks. Errors may go unlogged.

Risk:

Authentication routes lack error handling, meaning potential security incidents or operational failures during authentication may go unlogged and unaddressed, violating DPDP Section 8(6). This can lead to undetected breaches and prolonged system downtime.

Fix:

1. Wrap the authentication logic within the `useEffect` hook in `apps/web/modules/auth/sso/provider-view.tsx` with a try-catch block.
2. In the catch block, log the error details using a suitable logging mechanism (e.g., `console.error` or a dedicated logging service).
3. Redirect the user to a user-friendly error page, potentially including a generic error message and an error ID for support.
4. Ensure that sensitive PII is not logged directly in case of an error.

DPDP:

Section 8(6) — Breach: Any breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data shall be notified to the Data Protection Officer and the relevant regulatory authority.

Example:

```
useEffect(() => { const email = searchParams?.get("email"); try { if (props.provider === "saml") { if (!email) { router.push(`/auth/error?error=Email not provided`); return; } if (!props.isSAMLLoginEnabled) { router.push(`/auth/error?error=SAML login not enabled`); return; } signIn("saml", {}, { tenant: props.tenant, product: props.product }); } else if (props.provider === "google" && email) { signIn("google", {}, { login_hint: email }); } else if (props.provider === "microsoft") { signIn("azure-ad"); } else { signIn(props.provider); } } catch (error) { console.error("Authentication error:", error); router.push(`/auth/error?error=An unexpected error occurred during authentication.`); } // eslint-disable-next-line react-hooks/exhaustive-deps }, []);
```


Finding 19 of 88

[Section 8(1) — Security]

19. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / flags / features.repository.ts:14**Evidence snippet:** Uses WebhookSchema to pick fields, potentially including PII.**Estimated fix time:** 2–8 hours

PII flows from sso/provider-view.tsx to error/logging service (flags/features.repository.ts).

Ensure PII is redacted or hashed in logs.

Risk:

Personal Identifiable Information (PII) may be logged without proper redaction or hashing, increasing the risk of unauthorized disclosure and violating DPDP Section 8(1). This could lead to sensitive data exposure if logs are compromised or accessed inappropriately.

Fix:

1. Review all logging statements in `packages/features/flags/features.repository.ts` and any associated logging configurations.
2. Identify any PII fields that are being logged and implement redaction or hashing mechanisms before the data is written to logs.
3. Utilize a PII detection library or manual checks to ensure all sensitive fields are accounted for.
4. Configure log levels to ensure that detailed PII is only logged in development or debug environments, and is always redacted in production.

DPDP:

Section 8(1) — Security: Appropriate technical and organisational measures shall be taken to protect personal data against unauthorised or unlawful processing and against accidental loss, destruction or damage.

Example:

```
// Assuming a logging function that accepts data and a PII redaction utility import {
redactPII } from "@calcom/lib/pii-redaction"; // Hypothetical PII redaction utility function
logFeatureFlagUpdate(userId: number, featureName: string, newValue: any) { const sensitiveData
= { userId, featureName, newValue }; // Example data that might contain PII const redactedData
= redactPII(sensitiveData); console.log("Feature flag updated:", redactedData); } // Example
usage: // logFeatureFlagUpdate(123, "new_feature", { enabled: true, user_specific_setting:
"abc" });
```

Finding 20 of 88

[Section 8(1) — Security]

20. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / users / users.repository.ts:14

Evidence snippet: Uses WebhookSchema to pick fields, potentially including PII.

Estimated fix time: 2–8 hours

PII flows from oauth-client-users/oauth-client-users.controller.e2e-spec.ts to error/logging service (users/users.repository.ts). Ensure PII is redacted or hashed in logs.

Risk:

Personal Identifiable Information (PII) may be logged without proper redaction or hashing, increasing the risk of unauthorized disclosure and violating DPDP Section 8(1). This could lead to sensitive data exposure if logs are compromised or accessed inappropriately.

Fix:

1. Review all logging statements in `packages/features/users/users.repository.ts` and any associated logging configurations.
2. Identify any PII fields that are being logged and implement redaction or hashing mechanisms before the data is written to logs.
3. Utilize a PII detection library or manual checks to ensure all sensitive fields are accounted for.
4. Configure log levels to ensure that detailed PII is only logged in development or debug environments, and is always redacted in production.

DPDP:

Section 8(1) — Security: Appropriate technical and organisational measures shall be taken to protect personal data against unauthorised or unlawful processing and against accidental loss, destruction or damage.

Example:

```
// Assuming a logging function that accepts data and a PII redaction utility import {
redactPII } from "@calcom/lib/pii-redaction"; // Hypothetical PII redaction utility function
logUserUpdate(userId: number, updateData: any) { const sensitiveData = { userId, ...updateData
}; // Example data that might contain PII const redactedData = redactPII(sensitiveData);
console.log("User data updated:", redactedData); } // Example usage: // logUserUpdate(456, {
email: "test@example.com", name: "Test User" });
```

Finding 21 of 88

[Section 8(1) — Security]

21. [LOW] PII_FLOW_TO_LOGGING — packages / app-store / _utils / getCalendar.ts**Estimated fix time:** 1–4 hours

PII flows from services/shared-routing-form-response.service.ts to error/logging service (_utils/getCalendar.ts). Ensure PII is redacted or hashed in logs.

Risk:

PII data may be logged without proper redaction or hashing, violating data security obligations and potentially exposing sensitive user information.

Fix:

1. Review the `services/shared-routing-form-response.service.ts` file to identify where PII is being logged.
2. Implement redaction or hashing for any PII fields before they are passed to the logging service within `services/shared-routing-form-response.service.ts`.
3. Add explicit logging configurations or middleware in the application's logging setup to ensure PII is masked by default.

DPDP:

Section 8(1) — Security

Example:

```
import { createLogger } from '@your-logging-lib'; const logger = createLogger(); function processUserData(user: { name: string; email: string }) { // Redact PII before logging const redactedUser = { ...user, email: user.email.replace(/./g, '*') }; logger.info('Processing user data', { user: redactedUser }); }
```

Finding 22 of 88

[Section 8(1) — Security]

22. [LOW] PII_FLOW_TO_LOGGING — packages / features / availability / lib / getUserAvailability.ts**Estimated fix time:** 1–4 hours

PII flows from services/shared-routing-form-response.service.ts to error/logging service (lib/getUserAvailability.ts). Ensure PII is redacted or hashed in logs.

Risk:

PII data may be logged without proper redaction or hashing, violating data security obligations and potentially exposing sensitive user information.

Fix:

1. Review the `services/shared-routing-form-response.service.ts` file to identify where PII is being logged.
2. Implement redaction or hashing for any PII fields before they are passed to the logging service within `services/shared-routing-form-response.service.ts`.
3. Add explicit logging configurations or middleware in the application's logging setup to ensure PII is masked by default.

DPDP:

Section 8(1) — Security

Example:

```
import { createLogger } from '@your-logging-lib'; const logger = createLogger(); function processUserData(user: { name: string; email: string }) { // Redact PII before logging const redactedUser = { ...user, email: user.email.replace(/./g, '*') }; logger.info('Processing user data', { user: redactedUser }); }
```

Finding 23 of 88

[Section 8(1) — Security]

23. [LOW] PII_FLOW_TO_LOGGING — packages / features / bookings / lib / host-filtering / findQualifiedHostsWithDelegationCredentials.ts

Estimated fix time: 1–4 hours

PII flows from services/shared-routing-form-response.service.ts to error/logging service (host-filtering/findQualifiedHostsWithDelegationCredentials.ts). Ensure PII is redacted or hashed in logs.

Risk:

PII data may be logged without proper redaction or hashing, violating data security obligations and potentially exposing sensitive user information.

Fix:

1. Review the `services/shared-routing-form-response.service.ts` file to identify where PII is being logged.
2. Implement redaction or hashing for any PII fields before they are passed to the logging service within `services/shared-routing-form-response.service.ts`.
3. Add explicit logging configurations or middleware in the application's logging setup to ensure PII is masked by default.

DPDP:

Section 8(1) — Security

Example:

```
import { createLogger } from '@your-logging-lib'; const logger = createLogger(); function processUserData(user: { name: string; email: string }) { // Redact PII before logging const redactedUser = { ...user, email: user.email.replace(/./g, '*') }; logger.info('Processing user data', { user: redactedUser }); }
```

Finding 24 of 88

[Section 8(1) — Security]

24. [LOW] PII_FLOW_TO_LOGGING — packages / features / bookings / repositories / BookingRepository.ts

Estimated fix time: 1–4 hours

PII flows from services/shared-routing-form-response.service.ts to error/logging service (repositories/BookingRepository.ts). Ensure PII is redacted or hashed in logs.

Risk:

PII data may be logged without proper redaction or hashing, violating data security obligations and potentially exposing sensitive user information.

Fix:

1. Review the `services/shared-routing-form-response.service.ts` file to identify where PII is being logged.
2. Implement redaction or hashing for any PII fields before they are passed to the logging service within `services/shared-routing-form-response.service.ts`.
3. Add explicit logging configurations or middleware in the application's logging setup to ensure PII is masked by default.

DPDP:

Section 8(1) — Security

Example:

```
import { createLogger } from '@your-logging-lib'; const logger = createLogger(); function processUserData(user: { name: string; email: string }) { // Redact PII before logging const redactedUser = { ...user, email: user.email.replace(/./g, '*') }; logger.info('Processing user data', { user: redactedUser }); }
```

Finding 25 of 88

[Section 8(1) — Security]

25. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / busyTimes / lib / getBusyTimesFromLimits.ts:15

Evidence snippet: The `withReporting` wrapper is used, which is a custom Sentry wrapper. This indicates that errors and potentially other data, including PII if present, could be sent to Sentry.

Estimated fix time: 2–8 hours

PII flows from services/shared-routing-form-response.service.ts to error/logging service (lib/getBusyTimesFromLimits.ts). Ensure PII is redacted or hashed in logs.

Risk:

PII may be sent to Sentry via the `withReporting` wrapper without proper redaction, violating the security obligations under DPDP Section 8(1). This could lead to unauthorized disclosure of personal data in logs.

Fix:

1. Review the implementation of `withReporting` in `@calcom/lib/sentryWrapper.ts` to ensure PII is redacted before being sent to Sentry.
2. If `\_getBusyTimesFromLimits` receives or processes PII, implement redaction logic within the function or the `withReporting` wrapper.
3. Configure Sentry to mask or ignore fields that may contain PII if they are inadvertently sent.

DPDP:

Section 8(1) — Security

Example:

```
import { withReporting } from "@calcom/lib/sentryWrapper"; const _getBusyTimesFromLimits =
async (...) => { // ... processing logic ... return limitManager.getBusyTimes(); }; export
const getBusyTimesFromLimits = withReporting(_getBusyTimesFromLimits,
"getBusyTimesFromLimits");
```

Finding 26 of 88

[Section 8(1) — Security]

26. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / busyTimes / services / getBusyTimes.ts

Estimated fix time: 2–8 hours

PII flows from services/shared-routing-form-response.service.ts to error/logging service (services/getBusyTimes.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/busyTimes/services/getBusyTimes.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 27 of 88

[Section 8(1) — Security]

27. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / calendar-subscription / lib /

CalendarSubscriptionService.ts

Estimated fix time: 2–8 hours

PII flows from services/shared-routing-form-response.service.ts to error/logging service (lib/CalendarSubscriptionService.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/calendar-subscription/lib/CalendarSubscriptionService.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 28 of 88

[Section 8(1) — Security]

28. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / calendar-subscription / lib / cache /

CalendarCacheWrapper.ts

Estimated fix time: 2–8 hours

PII flows from services/shared-routing-form-response.service.ts to error/logging service (cache/CalendarCacheWrapper.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/calendar-subscription/lib/cache/CalendarCacheWrapper.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 29 of 88

[Section 8(1) — Security]

29. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / calendar-subscription / lib / sync /

CalendarSyncService.ts

Estimated fix time: 2–8 hours

PII flows from services/shared-routing-form-response.service.ts to error/logging service (sync/CalendarSyncService.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/calendar-subscription/lib/sync/CalendarSyncService.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 30 of 88

[Section 8(1) — Security]

30. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / calendar-subscription / lib / telemetry / CalendarTelemetryWrapper.ts

Estimated fix time: 2–8 hours

PII flows from services/shared-routing-form-response.service.ts to error/logging service (telemetry/CalendarTelemetryWrapper.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/calendar-subscription/lib/telemetry/CalendarTelemetryWrapper.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 31 of 88

[Section 8(1) — Security]

31. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / ee / workflows / lib / reminders / reminderScheduler.ts

Estimated fix time: 2–8 hours

PII flows from services/shared-routing-form-response.service.ts to error/logging service (reminders/reminderScheduler.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/ee/workflows/lib/reminders/reminderScheduler.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 32 of 88

[Section 8(1) — Security]

32. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / flags / repositories / PrismaTeamFeatureRepository.ts

Estimated fix time: 2–8 hours

PII flows from services/shared-routing-form-response.service.ts to error/logging service (repositories/PrismaTeamFeatureRepository.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/flags/repositories/PrismaTeamFeatureRepository.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 33 of 88

[Section 8(1) — Security]

33. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / flags / repositories /

PrismaUserFeatureRepository.ts

Estimated fix time: 2–8 hours

PII flows from services/shared-routing-form-response.service.ts to error/logging service (repositories/PrismaUserFeatureRepository.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/flags/repositories/PrismaUserFeatureRepository.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 34 of 88

[Section 8(1) — Security]

34. [MEDIUM] PII_FLOW_TO_LOGGING — packages / lib / sentryWrapper.ts**Estimated fix time:** 2–8 hours

PII flows from services/shared-routing-form-response.service.ts to error/logging service (lib/sentryWrapper.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/lib/sentryWrapper.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 35 of 88

[Section 8(1) — Security]

35. [MEDIUM] PII_FLOW_TO_LOGGING — packages / lib / intervalLimits / utils / getPeriodStartDatesBetween.ts**Estimated fix time:** 2–8 hours

PII flows from services/shared-routing-form-response.service.ts to error/logging service (utils/getPeriodStartDatesBetween.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/lib/intervalLimits/utils/getPeriodStartDatesBetween.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 36 of 88

[Section 8(1) — Security]

36. [MEDIUM] PII_FLOW_TO_LOGGING — packages / app-store / routing-forms / lib / formSubmissionUtils.ts**Estimated fix time:** 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (lib/formSubmissionUtils.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/app-store/routing-forms/lib/formSubmissionUtils.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 37 of 88

[Section 8(1) — Security]

37. [MEDIUM] PII_FLOW_TO_LOGGING — packages / emails / email-manager.ts**Estimated fix time:** 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (emails/email-manager.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/emails/email-manager.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 38 of 88

[Section 8(1) — Security]

38. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / bookings / lib / checkBookingLimits.ts**Estimated fix time:** 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (lib/checkBookingLimits.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/bookings/lib/checkBookingLimits.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 39 of 88

[Section 8(1) — Security]

39. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / bookings / lib / handleWebhookTrigger.ts**Estimated fix time:** 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (lib/handleWebhookTrigger.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/bookings/lib/handleWebhookTrigger.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 40 of 88

[Section 8(1) — Security]

40. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / bookings / lib / getAllCredentialsForUsersOnEvent / refreshCredentials.ts**Estimated fix time:** 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (getAllCredentialsForUsersOnEvent/refreshCredentials.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/bookings/lib/getAllCredentialsForUsersOnEvent/refreshCredentials.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 41 of 88

[Section 8(1) — Security]

41. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / bookings / lib / handleNewBooking / checkBookingAndDurationLimits.ts**Estimated fix time:** 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (handleNewBooking/checkBookingAndDurationLimits.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/bookings/lib/handleNewBooking/checkBookingAndDurationLimits.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 42 of 88

[Section 8(1) — Security]

42. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / bookings / lib / handleNewBooking / createBooking.ts

Estimated fix time: 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (handleNewBooking/createBooking.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/bookings/lib/handleNewBooking/createBooking.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 43 of 88

[Section 8(1) — Security]

43. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / bookings / lib / handleNewBooking / ensureAvailableUsers.ts

Estimated fix time: 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (handleNewBooking/ensureAvailableUsers.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/bookings/lib/handleNewBooking/ensureAvailableUsers.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 44 of 88

[Section 8(1) — Security]

44. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / bookings / lib / handleNewBooking / findBookingQuery.ts

Estimated fix time: 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (handleNewBooking/findBookingQuery.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/bookings/lib/handleNewBooking/findBookingQuery.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 45 of 88

[Section 8(1) — Security]

45. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / bookings / lib / handleNewBooking / getBookingData.ts

Estimated fix time: 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (handleNewBooking/getBookingData.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/bookings/lib/handleNewBooking/getBookingData.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 46 of 88

[Section 8(1) — Security]

46. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / bookings / lib / handleNewBooking / getEventType.ts

Estimated fix time: 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (handleNewBooking/getEventType.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/bookings/lib/handleNewBooking/getEventType.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 47 of 88

[Section 8(1) — Security]

47. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / bookings / lib / handleNewBooking / getLocationValuesForDb.ts

Estimated fix time: 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (handleNewBooking/getLocationValuesForDb.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/bookings/lib/handleNewBooking/getLocationValuesForDb.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 48 of 88

[Section 8(1) — Security]

48. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / bookings / lib / handleNewBooking / getRequiresConfirmationFlags.ts

Estimated fix time: 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (handleNewBooking/getRequiresConfirmationFlags.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/bookings/lib/handleNewBooking/getRequiresConfirmationFlags.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 49 of 88

[Section 8(1) — Security]

49. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / bookings / lib / handleNewBooking / loadAndValidateUsers.ts

Estimated fix time: 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (handleNewBooking/loadAndValidateUsers.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/bookings/lib/handleNewBooking/loadAndValidateUsers.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 50 of 88

[Section 8(1) — Security]

50. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / bookings / lib / handleNewBooking / scheduleNoShowTriggers.ts

Estimated fix time: 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (handleNewBooking/scheduleNoShowTriggers.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/bookings/lib/handleNewBooking/scheduleNoShowTriggers.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 51 of 88

[Section 8(1) — Security]

51. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / bookings / lib / handleNewBooking / validateBookingTimelsNotOutOfBounds.ts

Estimated fix time: 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (handleNewBooking/validateBookingTimelsNotOutOfBounds.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/bookings/lib/handleNewBooking/validateBookingTimelsNotOutOfBounds.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 52 of 88

[Section 8(1) — Security]

52. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / bookings / lib / handleNewBooking / validateEventLength.ts

Estimated fix time: 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (handleNewBooking/validateEventLength.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/bookings/lib/handleNewBooking/validateEventLength.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 53 of 88

[Section 8(1) — Security]

53. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / ee / round-robin / assignmentReason / AssignmentReasonRecorder.ts

Estimated fix time: 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (assignmentReason/AssignmentReasonRecorder.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/ee/round-robin/assignmentReason/AssignmentReasonRecorder.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 54 of 88

[Section 8(1) — Security]

54. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / ee / workflows / lib / reminders / scheduleMandatoryReminder.ts

Estimated fix time: 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (reminders/scheduleMandatoryReminder.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/ee/workflows/lib/reminders/scheduleMandatoryReminder.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 55 of 88

[Section 8(1) — Security]

55. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / webhooks / lib / getWebhooks.ts

Estimated fix time: 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (lib/getWebhooks.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/webhooks/lib/getWebhooks.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 56 of 88

[Section 8(1) — Security]

56. [MEDIUM] PII_FLOW_TO_LOGGING — packages / features / webhooks / lib / scheduleTrigger.ts**Estimated fix time:** 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (lib/scheduleTrigger.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/features/webhooks/lib/scheduleTrigger.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 57 of 88

[Section 8(1) — Security]

57. [MEDIUM] PII_FLOW_TO_LOGGING — packages / lib / server / defaultResponder.ts**Estimated fix time:** 2–8 hours

PII flows from bookings/organizations-teams-bookings.controller.e2e-spec.ts to error/logging service (server/defaultResponder.ts). Ensure PII is redacted or hashed in logs.

Risk:

Manual review required. Rule 'PII_FLOW_TO_LOGGING' fired on packages/lib/server/defaultResponder.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(1) — Security

Finding 58 of 88

[Section 8 — Data Principal Rights]

58. [MEDIUM] INCOMPLETE_DELETION_COVERAGE — N / A**Estimated fix time:** 2–8 hours

Deletion mechanism detected but may not cover all PII storage. Uncovered files: apps/api/v2/src/ee/bookings/2024-08-13/repositories/booking-references.repository.ts, apps/api/v2/src/ee/bookings/2024-08-13/repositories/bookings.repository.ts, apps/api/v2/src/ee/event-types-private-links/private-links.repository.ts, apps/api/v2/src/lib/repositories/prisma-access-code.repository.ts, apps/api/v2/src/lib/repositories/prisma-attribute.repository.ts. DPDP Section 8 requires complete erasure of all personal data across all systems when a user requests deletion.

Risk:

Manual review required. Rule 'INCOMPLETE_DELETION_COVERAGE' fired on see finding scope — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8 — Data Principal Rights

Finding 59 of 88

[Section 8(4) — Audit Trail]

59. [MEDIUM] AUDIT_TRAIL_PARTIAL — packages / features / booking-audit / lib / repository /

PrismaBookingAuditRepository.ts

Estimated fix time: 2–8 hours

Partial audit trail detected. Found: access logging, change tracking. Missing: dedicated audit model/table. DPDP Section 8(4) requires a structured audit trail with user identity, timestamp, action, and data accessed. A dedicated audit log table is required for proper compliance.

Risk:

Manual review required. Rule 'AUDIT_TRAIL_PARTIAL' fired on packages/features/booking-audit/lib/repository/PrismaBookingAuditRepository.ts — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(4) — Audit Trail

Finding 60 of 88

[Section 5 — Notice]

60. [MEDIUM] THIRD_PARTY_PII_SHARING — MULTIPLE:4

Evidence snippet: import { checkIfEmailsBlockedInWatchlistController } from
"@calcom/features/watchlist/operations/check-if-email-in-watchlist.controller";

Estimated fix time: 43–128 hours**Affected files (69):**

- apps/api/v1/lib/utlis/isLockedOrBlocked.ts
- apps/api/v1/next.config.js
- apps/web/app/api/auth/signup/handlers/calcomSignupHandler.ts
- apps/web/app/api/support/conversation/route.ts
- apps/web/modules/auth/verify-email-view.tsx
- apps/web/modules/billing/components/FullScreenUpgradeBanner.tsx
- ... and 63 more files

Personal data may flow to error monitoring service. Detected in 69 files: isLockedOrBlocked.ts, next.config.js, calcomSignupHandler.ts, route.ts and 65 more

Risk:

Manual review required. Rule 'THIRD_PARTY_PII_SHARING' fired on see finding scope — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 5 — Notice

Finding 61 of 88

[Section 8(3) — Retention]

61. [MEDIUM] RETENTION_MISSING — MULTIPLE**Estimated fix time:** 6–22 hours**Affected files (7):**

- apps/web/components/schemas/EventReservationSchema.tsx
- packages/features/bookings/lib/handleNewBooking/findBookingQuery.ts
- packages/features/bookings/lib/handleSeats/reschedule/attendee/attendeeRescheduleSeatedBooking.ts
- packages/features/bookings/lib/handleSeats/reschedule/owner/combineTwoSeatedBookings.ts
- packages/features/bookings/lib/handleSeats/reschedule/owner/moveSeatedBookingToNewTimeSlot.ts
- packages/features/bookings/lib/handleSeats/reschedule/rescheduleSeatedBooking.ts
- ... and 1 more files

Model/schema file contains PII fields but no retention or expiry signals detected. Detected in 7 files: EventReservationSchema.tsx, findBookingQuery.ts, attendeeRescheduleSeatedBooking.ts, combineTwoSeatedBookings.ts and 3 more

Risk:

Manual review required. Rule 'RETENTION_MISSING' fired on see finding scope — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 8(3) — Retention

Finding 62 of 88

[Section 11 — Data Portability]

62. [LOW] DATA_PORTABILITY_MISSING — N / A**Estimated fix time:** 2–8 hours

No data export or portability endpoint detected. DPDP Section 11 requires Data Fiduciaries to provide personal data in a commonly used, machine-readable format upon request.

Risk:

Manual review required. Rule 'DATA_PORTABILITY_MISSING' fired on see finding scope — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 11 — Data Portability

Finding 63 of 88

[Section 6 — Consent]

63. [LOW] CONSENT_MISSING — MULTIPLE:20**Evidence snippet:** const email = searchParams?.get("email");**Estimated fix time:** 20–80 hours**Affected files (31):**

- apps/web/modules/auth/sso/provider-view.tsx
- packages/embeds/embed-core/playground/lib/playground-init.ts
- packages/embeds/embed-core/playground/lib/playground.ts
- packages/features/ee/payments/components/Payment.tsx
- apps/web/modules/event-types/components/CreateEventTypeDialog.tsx
- apps/web/modules/onboarding/teams/invite/email/team-invite-email-view.tsx
- ... and 25 more files

Authentication form collects email for login/signup. Detected in 31 files: provider-view.tsx, playground-init.ts, playground.ts, Payment.tsx and 27 more

Risk:

Manual review required. Rule 'CONSENT_MISSING' fired on see finding scope — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 6 — Consent

Finding 64 of 88

[Section 9 — Children's Data]

64. [LOW] CHILDRENS_DATA_PATTERN — MULTIPLE**Estimated fix time:** 8–32 hours**Affected files (24):**

- apps/web/app/api/auth/signup/handlers/calcomSignupHandler.ts
- apps/web/app/api/auth/signup/handlers/selfHostedHandler.ts
- apps/web/lib/team/[slug]/getServerSideProps.tsx
- apps/web/modules/ee/organizations/delegationCredential.tsx
- apps/web/modules/ee/teams/components/TeamList.tsx
- apps/web/modules/event-types/components/Segment.tsx
- ... and 18 more files

Child/minor/student term paired with PII collection in same file. Detected in 24 files: calcomSignupHandler.ts, selfHostedHandler.ts, getServerSideProps.tsx, delegationCredential.tsx and 20 more

Risk:

Manual review required. Rule 'CHILDRENS_DATA_PATTERN' fired on see finding scope — see rule description for details.

Fix:

1. Review the finding description above and apply fixes per your compliance process.

DPDP:

Section 9 — Children's Data

Finding 65 of 88

[Section 7 — Legitimate Use]

65. [INFO] INTERNAL_ROUTE_PII_ACCESS — packages / features / eventtypes / lib / schemas.ts

Internal file (schemas.ts) accesses PII. Verify access is restricted to authorised contexts and PII is not exposed to logs or error responses.

Finding 66 of 88

[Section 7 — Legitimate Use]

66. [INFO] INTERNAL_ROUTE_PII_ACCESS — packages / features / ee / billing / service / proration / tasker / ProrationEmailTasker.ts

Internal service/utility accesses PII. Verify: (1) this file is only called from authorised contexts, (2) PII is not inadvertently exposed to logs or error messages.

Finding 67 of 88

[Section 7 — Legitimate Use]

67. [INFO] INTERNAL_ROUTE_PII_ACCESS — apps / web / app / api / cron / credentials / route.ts

Configuration or credential handler accesses connection PII. Verify: (1) credentials are loaded from environment variables not hardcoded, (2) connection strings are not logged in plaintext.

Finding 68 of 88

[Section 6 — Consent]

68. [PASS] CONSENT_PRESENT — apps / web / modules / ee / workflows / components / WorkflowDetailsPage.tsx

Consent covered via imported module: packages/lib/http-error.ts, packages/features/pbac/domain/types/permission-registry.ts

Finding 69 of 88

[Section 6 — Consent]

69. [PASS] CONSENT_PRESENT — apps / web / modules / bookings / views / bookings-single-view.tsx

Auth enforcement pattern detected inline — consent likely handled at registration.

Finding 70 of 88

[Section 6 — Consent]

70. [PASS] CONSENT_PRESENT — packages / app-store / exchange2013calendar / api / add.ts

Consent covered via imported module: packages/lib/http-error.ts

Finding 71 of 88

[Section 6 — Consent]

71. [PASS] CONSENT_PRESENT — apps / api / v2 / src / modules / router / controllers / router.controller.ts

Consent covered via imported module: packages/lib/http-error.ts

Finding 72 of 88

[Section 6 — Consent]

72. [PASS] CONSENT_PRESENT — apps / web / modules / ee / teams / components / AddNewTeamMembers.tsx

Auth enforcement pattern detected inline — consent likely handled at registration.

Finding 73 of 88

[Section 6 — Consent]

73. [PASS] CONSENT_PRESENT — apps / web / modules / signup-view.tsx

Consent covered via imported module: packages/lib/http-error.ts

Finding 74 of 88

[Section 6 — Consent]

74. [PASS] CONSENT_PRESENT — apps / web / modules / ee / workflows / views / WorkflowPage.tsxConsent covered via imported module: packages/lib/http-error.ts,
packages/features/pbac/domain/types/permission-registry.ts

Finding 75 of 88

[Section 6 — Consent]

75. [PASS] CONSENT_PRESENT — apps / web / modules / auth / oauth2 / authorize-view.tsx

Auth enforcement pattern detected inline — consent likely handled at registration.

Finding 76 of 88

[Section 6 — Consent]

76. [PASS] CONSENT_PRESENT — apps / web / modules / bookings / components / BookerWebWrapper.tsx

Consent covered via imported module: packages/lib/http-error.ts

Finding 77 of 88

[Section 6 — Consent]

77. [PASS] CONSENT_PRESENT — apps / api / v2 / src / ee / bookings / 2024-04-15 / controllers /
bookings.controller.tsConsent covered via imported module: packages/app-store/zoomvideo/_metadata.ts,
packages/lib/fetch-wrapper.ts

Finding 78 of 88

[Section 6 — Consent]

78. [PASS] CONSENT_PRESENT — apps / web / modules / embed / components / Embed.tsxConsent covered via imported module: packages/lib/http-error.ts,
packages/features/flags/repositories/PrismaTeamFeatureRepository.ts

Finding 79 of 88

[Section 6 — Consent]

79. [PASS] CONSENT_PRESENT — apps / api / v2 / src / ee / calendars / controllers / calendars.controller.tsConsent covered via imported module: packages/lib/http-error.ts,
packages/features/pbac/domain/types/permission-registry.ts

Finding 80 of 88

[Section 6 — Consent]

80. [PASS] CONSENT_PRESENT — packages / platform / atoms / booker / BookerPlatformWrapper.tsx
Consent covered via imported module: packages/app-store/zoomvideo/_metadata.ts,
packages/lib/http-error.ts

Finding 81 of 88

[Section 6 — Consent]

81. [PASS] CONSENT_PRESENT — apps / web / modules / ee / workflows / components / WorkflowStepContainer.tsx
Consent covered via imported module: packages/lib/http-error.ts

Finding 82 of 88

[Section 6 — Consent]

82. [PASS] CONSENT_PRESENT — apps / web / modules / team / type-view.tsx
Consent covered via imported module: packages/lib/http-error.ts

Finding 83 of 88

[Section 6 — Consent]

83. [PASS] CONSENT_PRESENT — packages / app-store / exchangecalendar / api / _postAdd.ts
Consent covered via imported module: packages/lib/http-error.ts

Finding 84 of 88

[Section 6 — Consent]

84. [PASS] CONSENT_PRESENT — apps / web / components / apps / routing-forms / TestForm.tsx
Consent covered via imported module:
packages/features/pbac/domain/types/permission-registry.ts

Finding 85 of 88

[Section 6(6) — Consent Withdrawal]

85. [PASS] CONSENT_WITHDRAWAL_PRESENT — apps / api / v2 / src / modules / billing / controllers /
billing.controller.ts

Consent withdrawal mechanism detected. Found in:
apps/api/v2/src/modules/billing/controllers/billing.controller.ts (line 108)

Finding 86 of 88

[Section 8 — Data Principal Rights]

86. [PASS] DELETION_MECHANISM_PRESENT — N / A

Data deletion mechanism detected. Found 0 deletion endpoint(s) and 724 deletion signal(s).
Cascade delete patterns detected.

Finding 87 of 88

[Section 8(6) — Breach]

87. [PASS] BREACH_INDICATORS_ADEQUATE — N / A

Logging and/or breach alerting present.

Finding 88 of 88

[Section 11 — Right to Access]

88. [PASS] DATA_ACCESS_PRESENT — apps / web / modules / members / getOrgMembersPageData.ts
Data access endpoint detected for authenticated users.

AI-Identified Compliance Gaps

The following gaps were identified by AI analysis and cross-validated. These are advisory observations, not verified rule violations. Human review is required before acting on these findings.

[AI-INFERRED] No explicit data access endpoint found

Confidence: 45%

Section 8 Right to Access

The rule engine coverage indicates 'DATA_PORTABILITY_MISSING' and 'INCOMPLETE_DELETION_COVERAGE'. While deletion is covered, there's no explicit mention or rule firing for a mechanism allowing users to **access** all their personal data, which is a core part of Section 8. The repository context also states 'data_flows' and 'pii_storage_locations' were not detected, hindering a direct code-level check, but the absence of a rule for data access is notable.

Recommendation: Implement an endpoint or feature that allows users to request and download all personal data held by the system, as per Section 8 of the DPDP Act.

[AI-INFERRED] DPO contact not exposed

Confidence: 40%

Section 10 Data Protection Officer

The rule engine fired 'GRIEVANCE_OFFICER_MISSING'. While this might cover a general contact for grievances, it doesn't specifically check for the explicit exposure of a Data Protection Officer (DPO) contact as required by Section 10. Without explicit code or configuration files provided, the absence of a rule targeting DPO contact information is a potential gap.

Recommendation: Ensure a Data Protection Officer's contact information is clearly published and accessible, potentially on a privacy policy page or a dedicated contact section, as mandated by Section 10.

[AI-INFERRED] Audit trail for data access not fully verified

Confidence: 50%

Section 8(4) Audit Trail

The rule engine coverage includes 'AUDIT_TRAIL_PARTIAL'. This suggests some audit logging exists, but it doesn't confirm if **all** personal data access events are logged, specifically as required by Section 8(4). The rule engine's partial finding implies a gap in comprehensive logging of data access.

Recommendation: Review and enhance the audit logging mechanism to ensure that every instance of personal data access, modification, or deletion is logged with sufficient detail (user, timestamp, data accessed) to comply with Section 8(4).

Deep Compliance Review

Overall Risk: HIGH

Our review reveals significant risks in how personal data is handled across multiple application layers, particularly concerning logging and third-party integrations. Sensitive PII is being logged without proper sanitization in error reporting tools like Sentry, and potentially shared with analytics platforms like PostHog without explicit user consent. Furthermore, data models store sensitive booking references without clear justification, and API controllers exhibit inconsistent PII handling and authentication for booking operations, increasing the likelihood of unauthorized access or disclosure.

Estimated remediation: 10 engineering day(s)

Most Critical Action: Implement robust PII sanitization within the `onErrorHandler.ts` to prevent sensitive data from being logged to Sentry, and ensure explicit consent mechanisms are in place before sending user-contextualized events to PostHog.

- **PII in Logging and Error Handling** [HIGH] — Article 5(1)(c) - Data Minimisation, Article 5(1)(f) - Integrity and Confidentiality — layers: Authentication & Session, API Routes & Controllers, Third-Party & PII Flows
- **Inconsistent PII Handling and Access Control** [HIGH] — Article 5(1)(a) - Lawfulness, Fairness and Transparency, Article 5(1)(f) - Integrity and Confidentiality — layers: API Routes & Controllers, Data Models & Storage
- **Unsanitized PII in Third-Party Integrations** [HIGH] — Article 5(1)(a) - Lawfulness, Fairness and Transparency, Article 5(1)(f) - Integrity and Confidentiality — layers: Third-Party & PII Flows

1. [HIGH] PII logged in Sentry without proper sanitization —

packages/trpc/server/onErrorHandler.ts — Article 5(1)(f) - Integrity and Confidentiality

The SentryModule is configured globally and captures exceptions. The `onError` handler logs errors using `captureException` which might include PII if not properly sanitized.

2. [HIGH] PII potentially shared with PostHog without explicit consent — N/A (conceptual flow) — Article 5(1)(a) - Lawfulness, Fairness and Transparency

The `posthog.capture('onboarding_completed')` call occurs after a user completes their profile. While the event name itself might not contain PII, the context implies PII is associated with the event without explicit consent.

3. [HIGH] Sensitive data in booking references without clear purpose — N/A (data model) —

Article 5(1)(c) - Data Minimisation

Booking references contain sensitive data without a clear, documented purpose, violating data minimisation principles.

4. [LOW] Inconsistent PII handling in booking creation — N/A (API route) — Article 5(1)(f) - Integrity and Confidentiality

The `createBooking` function relies on helper functions for PII processing, suggesting potential inconsistencies in how PII is managed during booking creation.

5. [MEDIUM] Broad data retrieval in calendar credentials — N/A (data model/service) — Article 5(1)(c) - Data Minimisation

Calendar credentials are retrieved broadly, potentially exposing more PII than necessary for the operation.

Layer Breakdown

Configuration & Secrets — 0 finding(s). The configuration layer appears to be well-structured with no direct DPDP compliance issues identified. The files reviewed focus on build configurations, internationalization setup, and API routing, none of which directly handle or expose personal data in a non-compliant manner. Existing findings from the rule engine are not repeated here.

Authentication & Session — 4 finding(s). The middleware layer appears to be primarily focused on request/response handling and URL manipulation. Several findings relate to the logging of request and response bodies, which is a common area for PII leakage if not carefully managed. The URL rewriting logic has a minor typo that should be corrected. Error handling in the OAuth2 controller is present but could be more robust for unknown error types.

API Routes & Controllers — 3 finding(s). This API layer handles booking creation and retrieval. While some endpoints have appropriate authentication and authorization, there are areas where PII handling during creation and retrieval needs further scrutiny. Specifically, the `createBooking` function's reliance on helper functions for PII processing and the less stringent access controls on `getBooking` present potential DPDP compliance risks related to data security and unauthorized access.

Data Models & Storage — 4 finding(s). This layer shows some potential risks related to the retrieval and handling of sensitive data, particularly in booking references and calendar credentials. While some functions are well-defined, others could benefit from more explicit justification for data access and stricter data minimization. The presence of unused code, though minor, also suggests a need for code hygiene that supports maintainability of compliance controls.

Third-Party & PII Flows — 4 finding(s). The error handling and third-party integrations (Sentry, PostHog) are areas of concern regarding PII. While some controls exist, the global nature of configurations and the potential for unhandled PII in error payloads or analytics events require closer scrutiny to ensure DPDP compliance.